

DEFENSIVE SECURITY • BUILT FOR AFRICA

KingaWeb

Product & Engineering Master Plan

A living blueprint from prototype to trusted African security platform

NORTH-STAR PROMISE KingaWeb helps organizations discover public-facing risks early, understand them in plain language, and close them through a verifiable remediation workflow.

Document owner: KingaWeb Product Team

Version 1.0 | 23 August 2026 | Status: Approved working baseline

How to use this master plan

This document is the durable decision record for KingaWeb. It defines what we are building, why it should exist, how it must be engineered, and what “complete” means for each release. It should evolve through controlled versions as customer evidence, regulation, threat patterns and technology change.

IMPORTANT DISTINCTION KingaWeb can reach 100% of a defined release, but a security platform is never permanently finished. After Version 1 reaches its release criteria, development continues through monitoring improvements, new integrations, threat research and regional expansion.

Decision hierarchy

- Safety and authorization outrank feature speed.
- Verified user problems outrank attractive but unsupported ideas.
- Reliable, explainable findings outrank a large count of noisy findings.
- Mobile usability and low-bandwidth operation are first-class requirements.
- A release is complete only when its acceptance, security, operational and documentation gates pass.

Document governance

Item	Rule
Change control	Major scope or architecture changes require a dated decision record.
Review cadence	Review monthly during build; quarterly after public launch.
Versioning	Major.Minor format; major for strategy/architecture changes, minor for clarified execution.
Source of truth	This document plus repository issues, ADRs and release checklists.
Definition of done	Code, tests, security checks, observability, documentation and acceptance evidence.

Contents

- 01 Executive vision and product thesis
- 02 Market position and differentiation
- 03 Users and jobs to be done
- 04 Product scope and capability map
- 05 Experience and interface system
- 06 System architecture
- 07 Scanner, findings and AI intelligence
- 08 Security, privacy and abuse prevention
- 09 Data model and APIs
- 10 Delivery roadmap
- 11 Engineering standards and testing
- 12 Infrastructure and operations
- 13 Commercial model and go-to-market
- 14 Metrics, risks and governance
- 15 Release-one completion checklist
- 16 Post-launch continuous development
- 17 Reference standards and glossary

1. Executive vision and product thesis

1.1 Vision

KingaWeb will become the trusted, accessible external security companion for African small and growing organizations: a platform that continuously maps what the internet can see, translates technical exposure into business impact, and guides owners or their service partners from detection to verified resolution.

1.2 The problem

Many organizations depend on websites, cloud services, email domains and third-party platforms without maintaining an accurate view of their public attack surface. Existing enterprise tools are often expensive, technically dense or designed for mature security teams. A simple scanner alone is not enough: it produces a moment-in-time list, while risk changes whenever certificates, DNS, code, hosting or suppliers change.

1.3 Product thesis

- Continuous visibility is more valuable than a one-time grade.
- Owners act faster when a finding explains business impact, ownership, priority and a tested fix.
- Local delivery channels—especially mobile and WhatsApp-ready communication—can turn security data into action.
- Agencies and managed-service partners are a scalable distribution channel because they already maintain client websites.
- Regional relevance must come from workflow, language, affordability and support—not from unsupported claims that African threats are entirely different.

1.4 Mission and boundaries

Mission: make responsible, continuous external security monitoring understandable and actionable for organizations that do not have a security operations centre.

Boundary: KingaWeb is a defensive monitoring and remediation platform. It is not an anonymous attack tool, an unrestricted penetration-testing service, a guarantee that a system is secure, or a replacement for a professional assessment where risk is high.

1.5 North-star outcome

NORTH-STAR METRIC Verified risk-reduction events per protected organization per month: a previously confirmed issue is fixed, automatically rechecked and closed with evidence.

2. Market position and differentiation

Public research shows relevant African cybersecurity consultancies and products already exist, including offerings for vulnerability assessment, website monitoring and SME subscriptions. KingaWeb must therefore earn distinction through execution and product depth; “first in Africa” will not be used without independently verifiable evidence.

2.1 Positioning statement

POSITION For African SMEs and the agencies that support them, KingaWeb is a mobile-first external security management platform that turns continuous technical signals into prioritized, bilingual remediation workflows and proof of improvement.

2.2 Differentiation pillars

Pillar	What KingaWeb does differently	Evidence of success
Action, not alarm	Each finding has owner, fix steps, due date, verification and evidence.	Higher verified closure rate; lower time-to-remediate.
African operating fit	Low-bandwidth UI, TZS/local pricing, Swahili/English, mobile-first alerts.	Strong mobile completion and regional activation.
Agency operating system	Multi-client workspaces, branded reports, delegated access and portfolio risk view.	Agencies adopt and retain multiple clients.
Trust through clarity	Explainable scoring, evidence timestamps, confidence levels and scan limitations.	Low dispute/false-positive rate.
Responsible by design	Ownership verification, safe scan profiles, audit logs and abuse controls.	No unauthorized-scan incidents; passed reviews.
From web to perimeter	Domains, DNS, TLS, email posture, exposed assets, impersonation and change monitoring.	Growing assets protected per customer.

2.3 Initial wedge and expansion

The entry product is website, TLS, DNS and email-domain posture monitoring. The expansion is a governed external attack-surface platform covering subdomains, approved services, public cloud exposures, third-party assets, impersonation signals and agency-managed remediation.

3. Users and jobs to be done

Persona	Primary job	Key anxiety	Success
Business owner	Know whether the digital business is exposed and what to do next.	Technical reports are confusing or unaffordable.	Clear priorities and proof that fixes worked.
Web agency	Protect many client sites without repetitive manual checking.	A client incident damages trust.	Portfolio view, reports and fast remediation.
Developer/IT lead	Detect configuration drift before customers or attackers do.	No time to watch every external signal.	Useful alerts, APIs and evidence.
Security consultant	Deliver repeatable assessments and track remediation.	Tool noise and fragmented evidence.	Controlled scanning and client-ready reporting.
Organization executive	Understand business exposure and trend without security jargon.	Unknown risk and unclear accountability.	Risk trend, ownership and audit trail.

3.1 Core journeys

1. Owner: create workspace → add domain → verify ownership → first scan → understand top three actions → assign or share → verify fix.
2. Agency: create portfolio → invite team → add clients → verify assets → review cross-client risk → generate branded report → track remediation.
3. Developer: receive alert → inspect evidence and request trace → apply configuration change → trigger safe rescan → close finding.
4. Executive: open monthly digest → view risk trend and critical open items → confirm responsible owner and due date.

4. Product scope and capability map

4.1 Capability domains

Domain	Release-one capability	Later evolution
Asset inventory	Verified domains, websites and DNS snapshots.	Subdomains, IP ranges, SaaS and cloud assets.
Web posture	HTTPS, TLS, headers, redirects, cookies and exposed metadata.	Safe crawling, API posture and supply-chain signals.
Email posture	SPF, DKIM discovery, DMARC and MX health.	BIMI, spoof simulations and domain abuse monitoring.
Change detection	Certificate, DNS, content hash and header changes.	Risk-aware diffs and maintenance windows.
Remediation	Guidance, ownership, status, evidence and rescan.	Ticketing integrations and verified automation.
Communication	Email and WhatsApp-ready share links/digests.	Provider integrations, SMS and webhooks.
Reporting	Current posture and trend PDF/CSV exports.	Compliance mappings and executive portfolios.
Platform	Workspaces, roles, audit log, billing-ready plans.	Partner marketplace and public API ecosystem.

4.2 Explicit non-goals for Release One

- Exploit execution, password attacks, denial-of-service testing or aggressive unauthenticated port scanning.
- Endpoint antivirus, full SIEM, employee surveillance or packet interception.
- Guaranteeing security or issuing legal/compliance certification.
- AI-generated findings without deterministic evidence and a documented rule.
- Native mobile applications before the responsive PWA experience proves insufficient.

5. Experience and interface system

5.1 Experience principles

- Calm, credible and precise: security urgency without fear-based marketing.
- Progressive disclosure: business meaning first, technical evidence second.

- Mobile-first: every critical journey works at 360 px width and on constrained networks.
- Accessible: WCAG 2.2 AA target, keyboard navigation, visible focus and non-color status cues.
- Bilingual architecture: English and Kiswahili strings externalized from the first production build.
- No dark patterns: transparent trials, pricing, data retention and cancellation.

5.2 Information architecture

Area	Primary screens
Public	Landing, free check, methodology, trust centre, pricing, legal, status.
Onboarding	Account, workspace, domain verification, first scan, result walkthrough.
Operate	Overview, assets, findings, scans, remediation, reports, alerts.
Agency	Client portfolio, team, assignments, white-label report configuration.
Administration	Roles, integrations, billing, audit log, data export/deletion.
Internal	Rules, scan queues, abuse review, support, service health, feature flags.

5.3 Dashboard hierarchy

The dashboard leads with: critical change since last scan; top three actions; overall trend; protected assets; recent scans; then deeper categories. A security score is never shown without its components, timestamp, confidence and limitations.

5.4 Design system

Visual identity uses deep forest green (#12392F), lime signal (#B9F34A), warm neutral surfaces and high-contrast ink. Components include severity badges, evidence cards, asset chips, trend charts, remediation timelines, verified-status markers, skeleton states and empty-state education. Storybook or an equivalent component catalogue becomes mandatory before public beta.

6. System architecture

ARCHITECTURE PRINCIPLE Separate the customer-facing control plane from the scanning data plane. Scanners are untrusted workers with minimal credentials, strict egress policy, bounded execution and no direct access to application secrets.

6.1 Target architecture

Browser/PWA → CDN and web application → API gateway → application services → PostgreSQL. The application publishes signed scan jobs to a queue. Isolated workers execute approved checks through controlled egress, store normalized evidence in object storage and results in PostgreSQL, then emit finding and notification events. A scheduler creates recurring jobs; an observability stack receives logs, metrics and traces.

Layer	Recommended direction	Reason
Web	Next.js with TypeScript	Strong server rendering, routing, PWA support and shared types.
API	NestJS/TypeScript or FastAPI/Python	Structured modules, validation and OpenAPI; choose one at foundation milestone.
Scanner	Python workers	Mature networking, DNS, TLS and security-analysis libraries.
Data	Managed PostgreSQL + Redis-compatible queue/cache	Relational integrity, JSON evidence and reliable jobs.
Artifacts	S3-compatible encrypted object storage	Reports and bounded evidence retention.
Identity	Managed OIDC initially	MFA, recovery and reduced authentication risk.
Infrastructure	Containers + infrastructure as code	Repeatability and future cloud portability.
Observability	OpenTelemetry + managed logs/metrics/errors	Vendor-neutral instrumentation and operational visibility.

6.2 Architectural qualities

- Tenant isolation at every query and object-storage path.
- Idempotent scan jobs with immutable job IDs and retry limits.
- Versioned rules, scores, APIs and evidence schemas.
- Horizontal worker scaling independent of web traffic.
- Graceful degradation: dashboards remain usable during scan backlog or notification outage.
- Regional deployment readiness without premature multi-region complexity.

6.3 Architecture decisions required before implementation

- Cloud/hosting provider and data region
- Primary backend framework
- Queue implementation

- Identity provider
- Notification providers
- Payment provider
- Retention policy and Tanzania legal review

7. Scanner and findings engine

7.1 Safe Release-One checks

Category	Checks	Default intensity
Reachability	Status, redirect chain, latency and uptime.	One bounded request plus validation.
TLS	Trust chain, protocol, hostname, expiry and selected configuration.	One handshake; no exhaustive cipher flood.
HTTP	Security headers, cookies, server disclosure, mixed-content indicators.	HEAD/GET with response-size ceiling.
DNS	A/AAAA, CNAME, NS, MX, CAA and changes.	Cached, rate-limited lookups.
Email	SPF, DMARC and DKIM-selector workflow.	Passive DNS checks.
Content	Unexpected change hash and approved defacement indicators.	Small bounded sample; no personal content retention.
Domain	Expiry where registry data permits; nameserver change.	Passive registry/RDAP data.
Technology	Conservative public fingerprinting with confidence.	No intrusive probing.

7.2 Finding contract

Every rule produces: stable rule ID; rule version; asset; observed time; severity; confidence; evidence; business impact; remediation; verification method; standards mappings; and false-positive feedback. Findings are deduplicated across scans and transition through Open, Acknowledged, In Progress, Resolved, Accepted Risk, False Positive and Reopened.

7.3 Scoring

The score is a transparent weighted posture indicator, not a security guarantee. Critical findings cap the score; confidence affects presentation, not hidden multiplication. Rule

weights and scoring versions are public. Historical scores remain tied to the scoring version used at the time.

7.4 False-positive discipline

- A rule needs fixtures for positive, negative and ambiguous states before release.
- Low-confidence signals are labeled informational until corroborated.
- Customers can dispute findings; dispositions feed rule review, not automatic suppression across tenants.
- Rule quality dashboard tracks confirmation rate, disputes and regression failures.

7.5 AI-powered real-time intelligence

KingaWeb's intelligence layer turns trusted observations into timely decisions. "Real-time" means event-driven processing immediately after an authorized change, scan result, provider signal or customer action; it does not mean intercepting private network traffic or continuously attacking targets. Deterministic rules remain the source of truth for findings. AI correlates, explains, prioritizes and assists.

7.5.1 Initial AI capabilities

Capability	Customer value	Required guardrail
Risk Copilot	Answers questions about the customer's own assets, evidence and fixes in English or Kiswahili.	Retrieval only from authorized workspace data; citations to evidence.
Change intelligence	Summarizes what changed across TLS, DNS, headers, technology and content signals.	No claim beyond observed diffs; confidence displayed.
Alert prioritization	Groups related events, suppresses duplicates and recommends urgency using business context.	Deterministic severity remains visible; user can override.
Remediation assistant	Produces stack-specific fix instructions, validation steps and draft tickets.	Human approval; never executes production changes in Release One.
Incident timeline	Builds a readable timeline from scans, changes, alerts and remediation actions.	Every statement links to timestamped source evidence.
Anomaly detection	Flags unusual deviations from an asset's historical baseline.	Starts informational; promotion requires evaluation and corroboration.
Executive digest	Converts posture changes into business-language daily/weekly summaries.	No invented causes, guarantees or compliance claims.
Feedback learning	Uses confirmed fixes and false-positive feedback to improve ranking.	Tenant isolation; controlled evaluation before model/rule changes.

7.5.2 Intelligence event pipeline

Authorized signal → immutable observation → deterministic rule evaluation → event stream → correlation window → anomaly/risk models → evidence-grounded explanation → policy gate → notification or recommended action → human decision → outcome feedback. Every stage carries tenant, asset, rule/model version, timestamp, confidence and correlation identifiers.

7.5.3 AI architecture

- Feature service computes bounded security features from normalized observations; raw untrusted page content is excluded by default.
- Correlation service groups related DNS, certificate, header, uptime and asset events within defined windows.
- Model gateway provides provider abstraction, redaction, model allowlists, budgets, timeouts and full request metadata without logging sensitive prompts by default.
- Retrieval layer searches only workspace-authorized evidence and approved remediation knowledge using tenant-scoped indexes.
- Policy engine validates outputs, blocks unsafe actions and requires human approval for notifications or integrations with meaningful impact.
- Evaluation service runs golden datasets, adversarial prompts, hallucination checks, bilingual quality tests and cost/latency benchmarks before rollout.
- AI telemetry records model/version, retrieved evidence IDs, confidence, policy decisions, user feedback and outcome—without exposing secrets.

7.5.4 AI safety requirements

- Treat websites, DNS text, tickets and user content as untrusted data, never as instructions to the model.
- Prevent prompt injection through strict context separation, input labeling, output validation and tool allowlists.
- No unrestricted agent loops, shell access, scanner control or network access from the language model.
- Authorization is enforced by application services; an AI response can never grant access.
- High-impact actions require explicit human confirmation and are executed by deterministic downstream services.
- Customers can disable generative features and request deletion under the documented retention policy.

- Model providers must not train on customer data unless a separate explicit agreement permits it.
- AI features launch behind flags with rollback, cost limits, safety monitoring and incident procedures.

7.5.5 AI delivery sequence

Private MVP: rule-based prioritization and evidence-grounded scan summaries. Private beta: Risk Copilot, change intelligence and draft remediation. Public V1: evaluated bilingual summaries, executive digests and feedback capture. V1.x: historical anomaly detection and cross-signal correlation. V2: carefully governed agent-assisted workflows, integrations and impersonation intelligence—still human-approved for consequential action.

8. Security, privacy and abuse prevention

8.1 Threat model

Primary threats include unauthorized target scanning, server-side request forgery, cross-tenant access, compromised worker containers, queue poisoning, credential theft, report leakage, malicious domains, denial of wallet through expensive scans, dependency compromise, insider misuse and manipulated evidence.

8.2 Required controls

Control area	Mandatory baseline
Authorization	Verify domain by DNS TXT, hosted file or meta tag before recurring or expanded scans.
SSRF	Resolve before request; reject private, loopback, link-local, reserved and metadata addresses; revalidate every redirect and connection.
Isolation	Ephemeral non-root workers, read-only filesystem, resource limits and no application-secret access.
Egress	Network policy, approved protocols/ports, destination validation, timeouts and response limits.
Identity	MFA for privileged roles, secure recovery, session rotation and step-up authentication.
Tenancy	Workspace-scoped authorization, database row policies/guards, object-path isolation and tests.
Secrets	Managed secret store, rotation, least privilege and no secrets in code/logs.
Audit	Append-only security events for roles, assets, scans, exports, billing and administrative action.

Control area	Mandatory baseline
Supply chain	Pinned dependencies, SBOM, secret scanning, SAST, dependency alerts and signed releases.
Data	Encryption in transit/at rest, minimization, retention schedule, export and deletion workflow.
Abuse	Rate limits, quotas, reputation signals, manual review and immediate kill switch.
Disclosure	Published vulnerability disclosure policy and response SLA before beta.

8.3 Secure development standard

Release One targets OWASP ASVS Level 2-aligned verification where applicable, OWASP Web Security Testing Guide coverage for relevant controls, and secure-by-design defaults. NIST CSF 2.0 informs KingaWeb’s customer-facing risk lifecycle: Govern, Identify, Protect, Detect, Respond and Recover.

AI features additionally follow the NIST AI Risk Management Framework’s Govern, Map, Measure and Manage functions and current OWASP GenAI guidance. Evaluation covers prompt injection, sensitive-data disclosure, insecure output handling, excessive agency, model/provider dependency, denial-of-wallet and overreliance.

8.4 Privacy principles

- Collect public technical evidence only when needed; avoid page bodies and personal data by default.
- Separate operational telemetry from customer scan evidence.
- Provide retention choices, export and deletion; document exceptions for fraud/security records.
- Do not sell customer data or use private evidence to train models without explicit agreement.
- Complete a Tanzania data-protection/legal review before public processing of customer information.

9. Data model and APIs

9.1 Core entities

Entity	Purpose	Key relationships
User	Person and authentication identity.	Memberships, assignments, audit events.

Entity	Purpose	Key relationships
Workspace	Tenant and billing boundary.	Members, clients, assets, plans.
Client	Agency-managed customer boundary.	Workspace and assets.
Asset	Verified domain/site/service.	Verification, scans, findings.
Verification	Ownership challenge and evidence.	Asset, requester and expiry.
ScanJob	Requested work and policy snapshot.	Asset, profile and worker run.
Observation	Immutable normalized evidence.	Scan job and rule evaluation.
Finding	Deduplicated risk lifecycle.	Asset, rule, observations, owner.
Remediation	Action, due date and verification trail.	Finding and assignee.
Notification	Delivery intent/result.	User, event and channel.
AuditEvent	Security/accountability record.	Actor, workspace, target.
RuleVersion	Detection and scoring logic metadata.	Observations and findings.

9.2 API principles

- REST/OpenAPI first; resource-oriented endpoints under /v1.
- Opaque identifiers; cursor pagination; ISO 8601 UTC timestamps.
- Idempotency keys on job creation, billing and high-impact mutations.
- Consistent problem-details errors with request correlation IDs.
- Strict validation, content-size limits and explicit authorization middleware.
- Signed, replay-resistant webhooks with retry and delivery history.

9.3 Initial endpoint groups

/auth and identity callbacks; /workspaces; /memberships; /clients; /assets; /verifications; /scans; /findings; /remediations; /reports; /notifications; /integrations; /audit-events; /billing; /webhooks. Administrative endpoints live on a separate internal surface.

10. Delivery roadmap

PLANNING RULE Dates are forecasts set after discovery and capacity review. Scope gates are fixed; calendar promises are not made before the team can estimate from evidence.

Phase	Outcome	Exit gate
0 — Discovery	10–20 interviews; target segment and willingness-to-pay	Problem brief, risk register

Phase	Outcome	Exit gate
	evidence.	and design partner.
1 — Foundation	Production repo, design system, CI, architecture skeleton and threat model.	ADR set, staging environment and security baseline.
2 — Private MVP	Verified assets, safe scans, findings and manual rescan for 3–5 partners.	Useful results; no critical unresolved product-security issue.
3 — Private beta	Accounts, scheduling, history, alerts, remediation and agency workspace.	10 active organizations; reliability and feedback gates.
4 — Public V1	Billing, reports, trust centre, support and production operations.	All Release-One completion criteria pass.
5 — V1.x	Rule quality, Kiswahili, PWA, integrations and commercial optimization.	Retention and remediation metrics improve.
6 — V2 perimeter	Subdomain discovery, approved service exposure and impersonation workflows.	Expanded authorization and legal/safety review.
7 — Regional scale	Partner channel, regional payments, multilingual support and resilience.	Repeatable acquisition and operational capacity.

10.1 Phase 0 — discovery deliverables

- Interview script and consent statement; at least five businesses, five agencies and three developers/IT leads.
- Competitor matrix based on verified capabilities, pricing, audience and workflow —not marketing claims.
- Clickable mobile prototype tested with at least five target users.
- One design partner agreeing to verify assets and review findings regularly.
- Decision record: exact first segment, pricing hypothesis and Release-One boundary.

10.2 Foundation epics

- Monorepo and development environments
- Identity and tenant model
- Design tokens and component library
- Queue and isolated worker proof
- Rule SDK and fixtures
- Observability baseline
- Infrastructure as code

- Threat model and abuse controls

10.3 Release sequencing rule

A feature moves through Discovery → Designed → Threat-modeled → Implemented → Tested → Documented → Observed in staging → Released behind a flag → Measured. Work is not complete at code merge.

11. Engineering standards and testing

11.1 Repository standards

- Protected main branch, reviewed pull requests and conventional commit/release notes.
- Format, lint, type-check, unit and security checks required in CI.
- Architecture Decision Records for durable choices; RFCs for cross-cutting changes.
- Feature flags for risky or incomplete behavior; no environment-specific code branches.
- Generated database migrations reviewed and rehearsed with rollback/forward strategy.

11.2 Test pyramid

Level	Coverage expectation
Unit	Rules, scoring, validation, permissions and state transitions.
Component	API modules, repositories, queue behavior and notification rendering.
Integration	Database isolation, object storage, DNS/TLS fixtures and worker sandbox.
Contract	OpenAPI compatibility, webhook signatures and event schemas.
End-to-end	Critical onboarding, verification, scan, remediation, billing and deletion journeys.
Security	SAST, dependency/secret/container scanning, authorization tests and targeted DAST.
Resilience	Timeouts, retry storms, worker crashes, queue backlog and provider outages.
Accessibility	Automated checks plus keyboard, screen-reader and contrast review.
Performance	Mobile page budgets, API latency and controlled scan throughput.

11.3 Quality targets for public V1

- No open Critical or High product-security vulnerabilities; Medium issues have owners and deadlines.
- 99.9% monthly control-plane availability target after stabilization; status page reports incidents.
- P95 standard API latency under 500 ms excluding scan execution and third-party delays.
- Core web experience meets agreed mobile performance budget on representative constrained connection.
- All critical journeys pass keyboard and accessibility review.
- Backup restoration demonstrated, not merely configured.

12. Infrastructure and operations

12.1 Environments

Local development uses safe fixtures and a local mock target. Preview environments run per pull request with no production secrets. Staging mirrors production topology with synthetic data. Production access is least privilege, MFA protected, time bounded where possible and fully audited.

12.2 Deployment

- Build immutable images; generate SBOM; scan and sign release artifacts.
- Deploy database-compatible changes before application changes; use expand/contract migrations.
- Canary or gradual rollout for scanner rules and high-impact services.
- Automatic rollback only for well-understood health signals; otherwise operator-controlled rollback.
- Publish customer-visible incidents and material rule/scoring changes.

12.3 Observability and SLOs

Service indicator	Initial objective	Alerting principle
API availability	99.9% monthly after public launch	Page on sustained error-budget burn.
Scan completion	95% of routine scans finish within 10 minutes	Alert on backlog age and failure cluster.
Notification delivery	99% accepted by provider within 5	Alert on provider or template failures.

Service indicator	Initial objective	Alerting principle
	minutes	
Evidence durability	No acknowledged loss of committed scan evidence	Alert on storage/write verification.
Queue health	Oldest routine job below agreed threshold	Scale workers or pause intake safely.
Rule quality	Monitored dispute and confirmation rates	Disable/regress noisy rule versions.

12.4 Incident response

Maintain severity definitions, on-call ownership, containment playbooks, customer communication templates, forensic logging, legal escalation contacts and post-incident review. Conduct one tabletop exercise before public launch and at least twice yearly thereafter.

13. Commercial model and go-to-market

13.1 Plans hypothesis

Plan	Audience	Initial shape
Free	Owner evaluating posture	One verified domain, limited manual checks, current snapshot.
Starter	Small business	Daily monitoring, history, alerts and remediation workflow.
Business	Growing organization	More assets/users, reports, integrations and priority support.
Agency	Web/IT/security provider	Client portfolio, delegated roles, branded reports and volume pricing.
Enterprise/ Institution	Complex organization	Custom scope, SSO, retention, assurance and support agreement.

Pricing remains a hypothesis until discovery measures willingness to pay and support cost. Security essentials such as MFA, encryption and safe defaults are not premium upsells.

13.2 Launch motion

- Recruit Tanzanian web agencies as design and distribution partners.
- Offer a responsible free snapshot that requires verification for continuous monitoring.
- Publish practical English/Kiswahili remediation guides and transparent methodology.
- Turn verified improvements into anonymized case studies with customer consent.
- Partner with hosting providers, developer communities and SME associations after product evidence exists.

13.3 Trust centre before payment

Publish security overview, data handling, subprocessors, service status, vulnerability disclosure, acceptable-use policy, scan methodology, scoring methodology, limitations, contact channels and incident notification commitment.

14. Metrics, risks and governance

14.1 Product scorecard

Dimension	Primary measures
Activation	Verified domain and completed first scan within one session/day.
Value	Findings understood, assigned and verified closed.
Retention	Organizations with active protected assets and recurring review.
Quality	Confirmed finding rate, disputes, failed scans and alert usefulness.
Reliability	SLO attainment, queue delay and incident recovery.
Growth	Design-partner conversion, agency portfolio expansion and paid retention.
Safety	Unauthorized-scan attempts blocked, abuse incidents and security defects.
Support	Time to first response, resolution and repeated confusion themes.

14.2 Principal risks

Risk	Mitigation	Early warning
Scanner abuse	Verification, safe profiles, limits, review and kill switch.	Rejected private targets; unusual volume.
False confidence	Transparent scope, evidence and limitations; no	Score viewed without

Risk	Mitigation	Early warning
	guarantee language.	findings; customer disputes.
Noisy findings	Fixtures, confidence, rule telemetry and staged rollout.	High dispute or suppression rate.
Product compromise	Threat model, isolation, secure SDLC and independent review.	Secrets, auth anomalies, dependency alerts.
Weak demand	Discovery and paid design partners before feature expansion.	Low repeated usage or willingness to pay.
Cloud cost growth	Quotas, caching, job budgets and cost per protected asset.	Cost rises faster than active assets.
Regulatory error	Local legal review, minimization and documented processing.	Unclear retention or customer requests.
Brand collision	Formal company/trademark search and prompt domain registration.	Confusingly similar regional service.

15. Release-One completion checklist

MEANING OF 100% Release One is 100% only when every mandatory gate below is evidenced. Optional backlog size does not affect release completion.

Product and experience

- ☐ Target persona and problem validated
- ☐ English production copy complete; Kiswahili architecture ready
- ☐ All core journeys complete on mobile and desktop
- ☐ Empty, loading, error and offline-tolerant states designed
- ☐ Accessibility review passed
- ☐ Pricing and cancellation transparent

Core capabilities

- ☐ Account, workspace and role management
- ☐ Domain ownership verification
- ☐ Safe on-demand and scheduled scans
- ☐ TLS, HTTP, DNS and email-domain checks
- ☐ Versioned findings and transparent score
- ☐ History and change detection
- ☐ Assignment, remediation and verified rescan

- ☐ Alerts and downloadable report
- ☐ Agency portfolio baseline
- ☐ Audit log and account/data controls

AI intelligence

- ☐ Deterministic evidence remains authoritative
- ☐ Evidence-grounded summaries link to observations
- ☐ Model gateway, budgets and tenant-scoped retrieval implemented
- ☐ Prompt-injection and excessive-agency tests pass
- ☐ Human approval enforced for consequential actions
- ☐ Golden-set accuracy and bilingual evaluation accepted
- ☐ AI kill switch, rollback and provider-failure fallback proven
- ☐ Customer AI controls and retention disclosures published

Security and privacy

- ☐ Threat model reviewed
- ☐ SSRF and redirect protections tested
- ☐ Tenant isolation tests passed
- ☐ Worker sandbox and egress controls verified
- ☐ MFA for privileged access
- ☐ Secret and dependency scanning clean
- ☐ Data inventory, retention and deletion implemented
- ☐ Vulnerability disclosure and acceptable-use policies published
- ☐ Independent security review completed
- ☐ No open Critical/High security defects

Reliability and operations

- ☐ Production infrastructure reproducible
- ☐ Monitoring, logs, traces and alerts live
- ☐ Backups restored in rehearsal
- ☐ Incident response tabletop completed
- ☐ Status page and support process live
- ☐ SLO dashboards and runbooks approved
- ☐ Rollback and rule-disable mechanisms proven
- ☐ Cost and abuse limits configured

Business readiness

- ☐ At least 10 active pilot organizations or an approved evidence-based threshold
- ☐ Design partners confirm usefulness
- ☐ Billing and invoicing tested
- ☐ Terms, privacy and local legal review complete
- ☐ Customer onboarding and support material complete
- ☐ Launch metrics baseline captured

16. Post-launch continuous development

16.1 Operating cadence

Cadence	Activity
Daily	Service health, abuse signals, scan failures and security alerts.
Weekly	Rule-quality review, customer feedback triage and release train.
Monthly	Product metrics, cost, risk register and roadmap evidence review.
Quarterly	Threat model update, access review, restoration exercise and strategy review.
Twice yearly	Incident tabletop, independent security testing and policy review.
Annually	Business continuity exercise, pricing review and regional expansion decision.

16.2 Candidate evolution themes

- Passive subdomain and certificate-transparency discovery with authorization workflow.
- Controlled external service exposure inventory and safe configuration checks.
- Brand/domain impersonation monitoring and guided takedown evidence packs.
- Client-side dependency and change monitoring for payment/e-commerce pages.
- GitHub, Jira, Linear, Slack, email and approved WhatsApp provider integrations.
- Partner API and webhook ecosystem.
- Regional languages and payment options based on measured demand.
- Security posture benchmarking using anonymized, consented aggregates.
- AI-assisted explanation and remediation only with evidence grounding, review and deterministic guardrails.

16.3 Innovation filter

A proposed capability enters the roadmap only if it has a target user, verified problem, safety analysis, authorization model, measurable outcome, operational owner and sustainable cost. Novelty alone is insufficient.

17. Reference standards and glossary

17.1 Standards baseline

Reference	How KingaWeb uses it
NIST CSF 2.0	Customer risk lifecycle and organizational governance vocabulary.
OWASP ASVS	Application-security requirements and release verification baseline.
OWASP WSTG	Relevant web-testing methodology and evidence design.
OWASP Attack Surface Analysis	Asset and exposure concepts.
CISA Secure by Design	Ownership of customer outcomes, safe defaults and transparency.
OWASP Top 10 / API Top 10	Threat awareness and engineering education—not a complete checklist.
NIST AI RMF / GenAI Profile	Governance, mapping, measurement and management of AI risk.
OWASP GenAI Security	Prompt injection, data disclosure, output handling and agency controls.
WCAG 2.2 AA	Accessibility target for customer-facing experiences.
OpenTelemetry	Vendor-neutral observability conventions.
Tanzania legal requirements	To be mapped with qualified local counsel before public launch.

17.2 Glossary

Asset. A verified public digital resource such as a domain or website.

Attack surface. The set of reachable assets and interfaces that could be targeted.

Control plane. The customer application, configuration and orchestration services.

Data plane. Isolated workers that execute approved checks and collect evidence.

Finding. A deduplicated security issue with evidence and lifecycle.

Observation. Immutable technical evidence from one check at one time.

Rule. Versioned logic that interprets observations.

Verified remediation. A fix confirmed through a subsequent applicable check.

Design partner. An early customer who provides structured, repeated product feedback.

SLO. A measurable reliability objective for a service.

Sources consulted

- NIST. Cybersecurity Framework 2.0 and Small Business Quick Start resources. <https://www.nist.gov/cyberframework>
- OWASP. Web Security Testing Guide. <https://wstg.owasp.org/>
- OWASP. Attack Surface Management Top 10 and Attack Surface Analysis Cheat Sheet. <https://owasp.org/>
- CISA and international partners. Shifting the Balance of Cybersecurity Risk: Principles and Approaches for Security-by-Design and -Default.
- NIST. AI Risk Management Framework and Generative AI Profile. <https://www.nist.gov/itl/ai-risk-management-framework>
- OWASP. GenAI Security Project and LLM Top 10. <https://genai.owasp.org/>
- Bank of Tanzania. National Payment Systems Annual Report 2025 (context for Tanzanian digital infrastructure).
- Public market review of Tanzanian/African cybersecurity services and SME security-monitoring products, August 2026. Competitor capabilities must be revalidated during discovery.

Approval record

Role	Name	Decision	Date
Product owner		☐ Approve ☐ Revise	
Engineering lead		☐ Approve ☐ Revise	
Security reviewer		☐ Approve ☐ Revise	
Design partner		☐ Acknowledge	